Rapport backend — AZƆ

Ce qui a été fait sur l'API (`azo-backend`) — pour Dorin

21 octobre 2026 · 7 commits poussés sur main (`8f00c7d9` à `a00f5b00`) · 33 suites / 396 tests verts · une partie reste à commiter (voir § 10)

1. En résumé

Connexion administrateur par mot de passe en production, suppression de clients, **retraits des prestataires**, erreurs FedaPay visibles, kilométrage des livraisons durci, étape « Je suis arrivé » du coursier personnel, pièces d'agence allégées. Un **audit complet** a été fait (§ 8) : il reste des points critiques avant un lancement public. `tsc` sans erreur.

> **Déploiement :** `/health` affichait `a00f5b00` en production. Le travail non commité (§ 10) apporte une migration (`20261021120000` , une colonne) : `render:start` exécute `prisma migrate deploy` avant le démarrage.

2. Connexion administrateur et console web

- `POST /auth/admin-login` (numéro + mot de passe haché scrypt, verrouillage après 5 échecs en 15 min, jeton de 12 h). Le code SMS de simulation `0000` n'ouvre plus un compte administrateur.
- `CORS_ORIGINS` (adresses autorisées, séparées par des virgules) est active en production : l'en-tête `access-control-allow-origin` renvoie l'adresse de la console, vérifié.
- `scripts/create-admin.js` lit `ADMIN_PASSWORD` dans l'environnement ; l'administrateur doit créer son mot de passe sur la vraie base.

3. Suppression d'un compte client

- `src/admin/client-deletion.ts` et `DELETE /admin/users/:id[?settle=1]` . Refusé pour son propre compte, un compte qui n'est pas client (prestataire, agence, administrateur), un client dont une course ou une livraison est en cours, un portefeuille non nul (sauf `settle=1`).
- Sans historique : le compte et ses données sont effacés. Avec historique (courses, livraisons, locations, mouvements d'argent) : **anonymisation** (nom, numéro, NPI, e-mail, appareils effacés ; numéro libéré ; courses et écritures gardées pour la comptabilité). `settle=1` remet le solde à zéro par une écriture « Solde remis à zéro à la suppression du compte ».
- Un commercial se supprime comme un client (filleuls détachés, profil de parrain supprimé) : **modification ajoutée par un autre outil dans mon commit, non testée sur base jetable**.
- `scripts/delete-client.js <numéro> --allow-remote [--confirm] [--solder]` : montre le compte, ne supprime que sur `--confirm` .
- **Vérifié sur base jetable** : client vierge supprimé, client avec historique anonymisé et numéro réinscriptible, refus (solde, course en cours, non-client, soi-même, inconnu), solde soldé avec écriture conservée.

4. Retrait des prestataires

- `POST /wallet/withdraw {amount, phone}` réservé aux rôles DRIVER, COURIER et AGENCY ; minimum 1 000 F ; numéro Mobile Money validé. Débit **conditionnel au solde** dans une transaction (deux demandes simultanées ne rendent plus le solde négatif) ; la demande est enregistrée **PENDING** avec le numéro à payer, les frais et le net.
- Console : `GET /admin/provider-withdrawals[?status=]`, `POST …/:id/paid {reference?}`, `POST …/:id/reject {reason}`. Payer ou refuser une demande déjà traitée est refusé ; un refus rend le montant au portefeuille **une seule fois** (la demande passe en `TRANSACTION_WITHDRAWAL_REFUSED`, donc ses frais ne comptent plus dans les gains). Le prestataire est notifié.
- **Vérifié sur base jetable** : demande, deux retraits simultanés (un seul passe, solde jamais négatif), paiement avec référence, refus avec remboursement, absence de double remboursement, refus du minimum, du numéro invalide et du solde insuffisant.
- **Limite** : le versement Mobile Money reste manuel ; aucun virement sortant FedaPay n'est branché.

5. Paiements FedaPay

- Un refus de FedaPay à la création d'une recharge est journalisé (cause, sans clé) et renvoyé à l'utilisateur au lieu d'une erreur muette.
- Les gros dépôts (610 000 F) échouaient, **cause non identifiée** : le code n'a aucun plafond. À vérifier : `FEDAPAY_ENV=live`, transactions refusées dans le tableau de bord FedaPay, plafonds des opérateurs.

6. Livraisons : kilométrage et coursier personnel

- **Kilométrage (mode strict, toutes les livraisons)** : `odometerStep(..., { strict: true })`. Cause du défaut : un GPS immobile dérive de 10 à 60 m ; l'ancien calcul comptait tout écart au-dessus du bruit puis déplaçait le point d'ancrage (9 870 m comptés en 10 min à l'arrêt quand la vitesse GPS est inconnue). Désormais : sous 5,4 km/h, un déplacement n'est compté que s'il atteint 80 m (vitesse proche de 0) ou 40 m (vitesse inconnue) ; au-dessus, seule la position compte (jamais la vitesse seule), elle doit dépasser le bruit et rester cohérente avec la vitesse (un saut de 80 m en 1,5 s à 2 m/s est ignoré). Un vrai trajet n'est pas perdu : la distance depuis l'ancrage est comptée dès qu'elle dépasse le seuil. Courses simples des Speeders inchangées.
- **« Je suis arrivé » (coursier personnel)** : `POST /deliveries/:id/arrive` (idempotent, réservé au coursier de la mission, mode PERSONAL, statut MATCHED), colonne `Delivery.courierArrivedAt` (migration `20261021120000_delivery_courier_arrived`, validée sur base jetable, aucun nouvel écart avec le schéma). Le départ avec le code est refusé tant que l'arrivée n'est pas signalée ; la livraison express n'est pas concernée. Pas de nouveau statut (une date, pour ne pas toucher une vingtaine de requêtes).
- **Notifications** en mode course personnelle (arrivée, départ, fin, paiement, annulation, nouvelle recherche) avec clés `NOTIFICATION_PERSONAL_*` en 4 langues.
- **Livreur express sans voiture** : `saveApplication` refuse GAZELLE, KOALA et LEOPARD pour un livreur express (avant d'ouvrir le dossier), en cohérence avec « Les voitures ne livrent pas de colis » de la grille tarifaire. Le coursier personnel les garde.
- Pièces d'agence : `STATUTS` et `EXTRAIT_CASIER` ne sont plus demandés (reste CNI, LOGO, RCCM, IFU).

7. Tests

- 396 tests verts sur 33 suites. Nouveaux : 8 tests du kilométrage strict (3 cas de GPS immobile, vitesse parasite sans mouvement, saut de GPS, vrai trajet de 2 km, trajet lent, arrêt puis reprise), 6 de « Je suis arrivé », 1 de la voiture refusée au livreur express, 9 de la connexion administrateur (journée précédente).
- Deux anciens tests ont été changés volontairement : « 1,2 m/s compte un petit déplacement » n'est plus vrai en mode strict ; il est remplacé par « 20 m en 2 s à 8 m/s sont comptés » et « 1 m annoncé par la vitesse n'est pas compté ».
- Non couverts par des tests du projet : retrait, suppression de client (vérifiés par des scripts jetables non conservés).

8. Audit complet de l'application (21 octobre)

Verdict : lancement public non recommandé avant les points critiques.

Niveau	Constat
Critique	**Création d'argent** : `POST /marketplace/orders` ne valide pas les prix des articles ; un prix négatif donne un total négatif et le « débit » crédite le portefeuille. Le séquestre n'est de toute façon jamais versé (fonction inachevée). À verrouiller ou désactiver tout de suite.
Critique	**Aucun SMS n'est envoyé** (pas de passerelle) et le serveur est en mode simulation : `0000` ouvre tout compte non administrateur, le code réel est renvoyé par l'API. Le changement de numéro écrit son code seulement dans les logs.
Critique	Pas de suppression de compte par l'utilisateur ni de pages légales (exigées par les stores) ; versement des retraits manuel.
Important	Solde non réservé : une course ou livraison peut rester bloquée si le client dépense son solde en route (le règlement lève « Solde insuffisant ») ; plusieurs livraisons commandables avec le même solde. `wallet.debit` n'est pas atomique (utilisé seulement par la boutique).
Important	Agences (audit précédent, toujours ouverts) : double débit possible à l'activation, plafond de comptes contournable, livraisons des coursiers d'agence à la commission standard, tableau de bord qui ignore les livraisons.
Important	`schema.prisma` et les migrations ne concordent pas : la table `RideSettlement` (utilisée en SQL direct) n'est pas dans le schéma ; un `prisma migrate dev` proposerait de la supprimer. Les clés étrangères de `RideTip` et `Agency.activationFee` diffèrent aussi. (Les index `Ride_clientId_driverId_idx` et `Ride_scheduledAt_idx` existent bien par migration.)
Important	Dépendances : 4 vulnérabilités graves côté serveur (`multer` , `axios` , `@nestjs/platform-express` , `fedapay`) ; 28 côté mobile, surtout des outils de compilation ; 0 pour la console.
Important	Exploitation : Render gratuit (le serveur s'endort, les tâches `setInterval` s'arrêtent avec lui) ; `STRICT_PRODUCTION=false` (clé JWT par défaut possible si `JWT_SECRET` manque) ; mot de passe de la base à changer (adresse collée deux fois dans un échange).
Moyen	Codes de connexion écrits dans les logs (`[OTP DEV]`) ; jeton accepté dans l'adresse (`?token=`) ; pièces de plus de 5 Mo sur le disque éphémère ; pas de limite globale de requêtes ni d'en-têtes `helmet` .
Solide	Contrôle d'accès des courses et livraisons ; état du compte relu à chaque requête ; clés NPI obligatoires ; commission atomique ; prix calculé par le serveur ; migrations appliquées au démarrage ; 396 tests verts.

Non vérifié : notifications poussées, temps réel (socket), cartes et iPhone en production, un vrai paiement de bout en bout, l'APK allégé sur un téléphone.

9. Comptes de test (scripts, à lancer par vous sur la base)

- `scripts/create-agency.js` (agence activée, niveau au choix, chauffeurs de test), `scripts/create-provider.js` (Speeder essence ou électrique, voiture, coursier personnel, livreur express), `scripts/delete-client.js`. Aucun n'est lancé automatiquement ; ils exigent `--allow-remote` hors base locale. Supprimer ces comptes avant le lancement public.

10. Commits et état

Commit	Contenu
`a00f5b00`	Retrait des prestataires vers Mobile Money (demande en attente, paiement manuel, refus avec remboursement)
`46262e4b`	Administration retirée du mobile, console adaptée au téléphone
`03ce4956`	« Solder et supprimer » (portefeuille non nul)
`69748e1a`	Suppression d'un compte client, script `delete-client.js`
`df5ac739`	Inscription d'agence, pièces sans statuts ni casier
`7adc8eb1`	Recharge FedaPay refusée : cause journalisée et affichée
`8f00c7d9`	Connexion administrateur par mot de passe

> **Pas encore commité** : kilométrage strict (`odometer.ts` , `delivery.module.ts`), « Je suis arrivé » et sa migration, notifications de course personnelle, refus des voitures pour le livreur express, tests associés.